

Sicherheit in Netzwerken

Risiken verstehen, Schutz erklären, Kunden beraten

Das große Ganze

Moderne Unternehmen existieren heute nicht mehr ohne Netzwerke: Jede Bestellung, jeder Zahlungsvorgang und jede E-Mail läuft über digitale Leitungen. Bricht das Netzwerk zusammen oder wird Kommunikation manipuliert, steht das gesamte Geschäft still. In dieser Vorlesung lernst du Netzwerksicherheit nicht als abstrakte Protokoll-Bastelei, sondern aus der Beratungsperspektive: Welche Geschäftsrisiken drohen und wie schützt man die Unternehmenswerte?

Orientierung

Unser roter Faden folgt dem Weg der Daten: vom lokalen Anschluss am Schreibtisch über die weltweiten Transportwege des Internets bis zur Anwendung beim Nutzer – verknüpft mit den drei Schutzzielen der CIA-Triade (Vertraulichkeit, Integrität, Verfügbarkeit).

Prüfungsfokus

In der Klausur musst du Angriffe den Schutzzielen der CIA-Triade zuordnen, die passende Gegenmaßnahme benennen und erklären können, warum moderne Sicherheit über reine Burgmauern (Perimeter) hinausgehen muss.

Agenda

- **Geschäftsrisiken** – warum Netzwerksicherheit alle Unternehmen betrifft
- **Orientierungsmodell** – wo Kommunikation angegriffen werden kann
- **Zugang und lokales Netz** – wer oder was darf sich verbinden?
- **Datenwege im Internet** – wem vertrauen wir beim Transport?
- **Verfügbarkeit von Diensten** – wie entstehen Überlastung und Ausfall?
- **Anwendungen und Sitzungen** – wie werden Nutzer umgeleitet oder übernommen?
- **Schutzkonzept und Beratung** – mehrere Schutzlinien sinnvoll kombinieren

Strukturüberblick

Die Gliederung folgt dem Weg eines Datenpakets: Wir starten bei den geschäftlichen Risiken, nutzen ein vereinfachtes 3-Stufen-Modell als Landkarte (Zugang → Transport → Anwendung) und betrachten auf jeder Ebene Bedrohungen und Schutzprinzipien, bevor wir alles in einem schlagkräftigen Schutzkonzept (Defense in Depth) zusammenführen.

Lern-Strategie

- **Grundlagen & Schichten:** Die Dreiteilung (Zugang, Transport, Anwendung) als gedankliches Ordnungssystem verinnerlichen.
- **Angriffe & Schutzziele:** Zu jedem Angriff wissen, welches Schutzziel verletzt wird (Mitlesen = Vertraulichkeit; Umleitung = Integrität; DDoS = Verfügbarkeit).
- **Spezifische Mechanismen:** ARP-Spoofing, SYN-Flood, Session Hijacking, DNS-Spoofing sicher erklären können.
- **Architektur & Beratung:** Defense in Depth und Segmentierung vs. Zero Trust sauber abgrenzen.

Typische Klausur-Schwerpunkte

Transferfragen lauten häufig: „Ein Kunde klagt über Vorfall X. Auf welcher Ebene liegt das Problem, welches Schutzziel ist verletzt und welche zwei Maßnahmen empfehlen Sie?“

Warum ist Netzwerksicherheit so wichtig?

Die Angriffsfläche der vernetzten Welt

Worum geht es in diesem Kapitel?

Wir schaffen das geschäftliche Fundament: Warum reicht das alte Konzept vom „sicheren Firmennetzwerk“, nicht mehr aus? Durch Cloud, Homeoffice und IoT gibt es keinen geschützten Innenraum mehr. Wir klären die Schlüsselbegriffe Angriffsfläche (Attack Surface), Perimeter und warum interne Abschottung lebenswichtig ist.

Modul-Lernziel

Du kannst den Begriff Angriffsfläche definieren, das Zusammenspiel von Initial Access und Lateral Movement erklären und begründen, warum die klassische Perimeter-Sicherheit überholt ist.

Typische Schwerpunkte

Definition der Angriffsfläche mit Beispielen, Target-Fallstudie (Heizungsbauer-Einstieg) und der Paradigmenwechsel vom Burg-Modell zu Zero Trust.

Jedes Gerät hängt am Netzwerk

- Vernetzt sind nicht nur Laptops, sondern auch **Drucker, Maschinen, Kameras und Sensoren**
- Cloud-Dienste und Partner schaffen zusätzliche Verbindungen außerhalb des Unternehmens
- Jedes Gerät und jede Verbindung erweitert die **Angriffsfläche**
- Ein unauffälliges Gerät kann zum Einstieg in kritische Systeme werden

Geschäftsfrage: Wissen wir, welche Geräte mit unserem Netzwerk verbunden sind?

💡 Auf den Punkt gebracht (Einfach erklärt)

Im Firmennetzwerk hängen heute oft mehr „stumme“ Geräte als Computer: smarte Kaffeemaschinen, Überwachungskameras, Etikettendrucker und Lüftungssteuerungen. Viele dieser Geräte haben uralte Software, Standardpasswörter und werden nie aktualisiert. Für Hacker sind sie die perfekte offene Hintertür, um unbemerkt ins Unternehmensnetzwerk einzudringen. *Alltagsanalogie:* Du sicherst deine Villa mit einer Panzerglastür und Alarmanlage ab, lässt aber die kleine Katzenklappe im Keller sperrangelweit offen. Einbrecher zwängen sich durch die Katzenklappe und stehen mitten im Haus. *Target-Vorfall 2013:* Angreifer stahlen Zugangsdaten eines Klimatechnik-Subunternehmers und erbeuteten über das Lüftungsnetzwerk die Kreditkartendaten von 40 Millionen Kunden!

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Erklären können, warum Inventarisierung (**Asset Management**) die unverzichtbare Basis ist („Was du nicht kennst, kannst du nicht schützen,“) und wie nicht-patchbare Altgeräte abgesichert werden (durch **Netzwerksegmentierung / Isolierung**).
- **Typische Klausurfälle:** Annehmen, man müsse nur Laptops und Server schützen. IoT- und Haustechnik-Geräte erweitern die **Angriffsfläche** massiv!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Warum stellen smarte IoT-Geräte (z. B. IP-Kameras oder vernetzte Drucker) ein hohes Sicherheitsrisiko im Unternehmensnetzwerk dar? Nennen Sie zwei Gründe und eine wirksame Gegenmaßnahme.“

„**Antwort:**

- **Fehlende Updates / Standardpasswörter:** Geräte erhalten selten Sicherheits-Patches und laufen oft mit unsicheren Werkseinstellungen.
- **Vergrößerung der Angriffsfläche:** Jedes zusätzliche Gerät bietet Angreifern einen potenziellen Einstiegspunkt (**Initial Access**).
- **Gegenmaßnahme:** Konsequente **Netzwerksegmentierung (VLANs)**, sodass IoT-Geräte in einem isolierten Netzbereich ohne Zugriff auf kritische Systeme laufen.

Zugriff von überall möglich

- Homeoffice, mobile Geräte und Cloud-Dienste lösen die klassische **Unternehmensgrenze** auf
- Angriffe sind weltweit möglich und rund um die Uhr automatisierbar
- Gestohlene Zugangsdaten oder ein ungeschütztes Gerät können den Einstieg ermöglichen
- Danach entscheidet die interne Abschottung über das Schadensausmaß

Merksatz: Ein Netzwerk ist nur so sicher wie sein schwächstes angeschlossenes Gerät.

💡 Auf den Punkt gebracht (Einfach erklärt)

Ein Cyberangriff läuft fast immer in zwei getrennten Schritten ab:

1. **Initial Access (Erstzugang):** Der Einbrecher gelangt irgendwie durch ein Fenster oder eine Tür ins Haus (z. B. Phishing-Mail oder gestohlenes Passwort).
2. **Lateral Movement (Seitwärtsbewegung):** Der Einbrecher bewegt sich von Zimmer zu Zimmer, bricht Schränke auf und sucht den Tresor. *Kernaussage:* Den Initial Access kann man bei tausenden Mitarbeitern nie zu 100 % verhindern. Die eigentliche Schadenshöhe entscheidet sich beim Lateral Movement: Wenn das Netzwerk intern offen ist wie eine Scheune, hat der Angreifer leichtes Spiel.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die Phasen **Initial Access** und **Lateral Movement** definieren und je eine gezielte Schutzmaßnahme zuordnen können.
- **Typische Klausurfälle:** Glauben, dass mit einer Firewall am Außenzugang alles erledigt sei. Ein Netzwerk muss **im Inneren** gegen Seitwärtsbewegungen abgeschottet sein!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Unterscheiden Sie ‚Initial Access‘ und ‚Lateral Movement‘ und nennen Sie für jede Phase eine geeignete Schutzmaßnahme.“ **Antwort:**

- **Initial Access:** Der erstmalige Einbruch/Zugang in das Netzwerk (z. B. via Phishing, kompromittiertes VPN-Passwort). Schutz: **Mehrfaktor-Authentifizierung (MFA)** oder **Security Awareness**.
- **Lateral Movement:** Die unbefugte Weiterverbreitung des Angreifers von System zu System innerhalb des internen Netzes. Schutz: **Netzwerksegmentierung** und das **Prinzip der minimalen Rechte (Least Privilege)**.

Perimeter-Sicherheit reicht nicht mehr

Früher

- Klare Netzwerkgrenze (Perimeter)
- Firewall am Übergang zum Internet
- „Innen sicher, außen unsicher,“

Heute

- Homeoffice, Cloud, mobile Geräte
- Keine klare Grenze mehr
- Prinzip **Zero Trust**: jede Verbindung wird geprüft, egal woher

💡 Auf den Punkt gebracht (Einfach erklärt)

Das alte Sicherheitsmodell funktionierte wie eine mittelalterliche Burg: Ein tiefer Graben und dicke Mauern (**Perimeter**). Wer einmal über die Zugbrücke im Burghof stand, dem wurde blind vertraut. Heute arbeiten Mitarbeiter im Homeoffice, Server stehen in der Microsoft-/AWS-Cloud und Mobilgeräte wechseln ständig das Netz – die Burgmauern existieren nicht mehr! *Die neue Philosophie – Zero Trust*: „Vertraue niemandem, prüfe immer alles nach,“ (**Never trust, always verify**). Selbst wenn jemand im internen Büro-WLAN sitzt, wird bei jedem einzelnen Klick geprüft: Wer bist du? Ist dein Laptop sicher? Darfst du wirklich auf diese Datei zugreifen?

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Den Paradigmenwechsel vom Burg-/Perimeter-Modell zu **Zero Trust** erklären und begründen, warum Standort im internen Netz kein Vertrauensbeweis mehr ist.
- **Typische Klausurfalle:** Zero Trust für ein Software-Produkt halten, das man im Laden kauft, oder behaupten, dass Firewalls durch Zero Trust überflüssig werden. Firewalls bleiben wichtig, sind aber nicht mehr die einzige Vertrauensgrenze!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Erläutern Sie den Leitsatz ‚Never trust, always verify‘ des Zero-Trust-Modells im Vergleich zum traditionellen Perimeter-Ansatz.“ **Antwort:**

- **Perimeter-Ansatz:** Basiert auf Standort-Vertrauen („innen sicher, außen unsicher,“); wer die Firewall passiert hat, genießt breites Vertrauen.
- **Zero Trust:** Kein Vertrauensvorschuss aufgrund des Netzwerkstandorts; **jeder einzelne Zugriff** auf Ressourcen wird dynamisch anhand von **Identität (MFA)**, **Gerätezustand** und **Kontext** authentifiziert und autorisiert.

Wo Kommunikation angegriffen werden kann

Das OSI-Modell als einfache Landkarte

Worum geht es in diesem Kapitel?

Wie findet man sich im Dschungel von hunderten Netzwerkprotokollen und Begriffen zurecht? Wir nutzen das OSI-Schichtenmodell nicht als akademische Schikane, sondern als praktische Navigationskarte: Es teilt die Kommunikation logisch auf, damit wir Angriffe und Gegenmaßnahmen sofort der richtigen Stelle zuordnen können.

Modul-Lernziel

Du verstehst den Sinn von Schichtenmodellen (Kapselung, Abstraktion) und kannst nachvollziehen, warum Schutzmaßnahmen immer genau auf der Schicht wirken müssen, auf der das Risiko entsteht.

Typische Schwerpunkte

Sinn eines Schichtenmodells, Kapselungsprinzip und die didaktische Reduktion auf die drei Bereiche Zugang, Transport und Anwendung.

Warum ein Schichtenmodell?

- Netzwerkkommunikation besteht aus mehreren aufeinander aufbauenden Aufgaben
- Das **OSI-Modell** ordnet sie vom physischen Zugang bis zur Anwendung
- Jede Ebene kann eigene Risiken und Schutzmaßnahmen haben
- Für Beratung und Vertrieb genügt eine vereinfachte Landkarte:
 - **Zugang – Transport – Anwendung**

💡 Auf den Punkt gebracht (Einfach erklärt)

Netzwerkkommunikation ist wie ein Briefversand: Du schreibst den Text (Anwendung), steckst ihn in einen Umschlag mit Empfängeradresse (Transport) und der Postbote transportiert ihn per Fahrrad oder LKW über die Straße (Zugang). Jede Ebene hat ihre eigene Aufgabe. *Warum ist das für Sicherheit wichtig?* Jede Ebene hat völlig andere Schwachstellen! Wenn du deinen Brief in feinstem Latein verschlüsselst (TLS auf Anwendungsebene), kann der Postbote den Umschlag trotzdem klauen oder an eine falsche Adresse werfen (Transportebene). Eine Maßnahme schützt immer nur ihre eigene Schicht!

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Erklären können, warum keine einzelne Schutzmaßnahme alle Ebenen absichern kann (Herleitung für **Defense in Depth**).
- **Typische Klausurfalle:** Zu glauben, dass TLS/HTTPS alle Netzwerkangriffe abwehrt. TLS schützt die Vertraulichkeit des Inhalts, aber nicht gegen Überlastung (DDoS) oder gefälschte Wegweiser (BGP)!

? Mögliche Klausurfrage & Antwortschizze

Frage: „Warum kann eine Ende-zu-Ende-Verschlüsselung (z. B. TLS) auf Anwendungsebene einen Denial-of-Service-Angriff auf Netzwerkebene nicht verhindern?“ **Antwort:**

- **Schichtentrennung:** TLS schützt den **Inhalt der Nutzdaten** (Vertraulichkeit und Integrität auf Schicht 5–7).
- **Unterschiedliche Angriffsebene:** Ein DoS-Angriff zielt auf die **Verfügbarkeit der Transport- oder Vermittlungsschicht** (Überflutung von Bandbreite oder Verbindungstabellen), bevor die TLS-Verbindung überhaupt verarbeitet werden kann.

Eine Landkarte in drei Bereichen

Bereich	Worum geht es?	Typisches Risiko
Anwendung	Webseiten, E-Mail, angemeldete Sitzungen	Täuschung oder Übernahme
Transport	Datenwege und Erreichbarkeit	Umleitung oder Überlastung
Zugang	Geräte, Kabel, WLAN, lokales Netz	Unbefugte Verbindung

Das technische OSI-Modell verfeinert diese Landkarte in sieben Schichten.

💡 Auf den Punkt gebracht (Einfach erklärt)

Das offizielle technische OSI-Modell hat 7 Schichten – für Management und Beratung bündeln wir diese in drei intuitive Zonen:

1. **Zugang (Schicht 1 & 2):** Die Hardware und das lokale Netz (Kabel, WLAN, Switches, MAC-Adressen). Risiko: Unbefugte stöpseln sich ein.
2. **Transport (Schicht 3 & 4):** Der weltweite Datenweg durchs Internet (IP, Router, TCP, UDP). Risiko: Daten werden umgeleitet oder Server überflutet.
3. **Anwendung (Schicht 5 bis 7):** Die sichtbaren Dienste für Menschen (Webseiten, E-Mail, Logins, DNS). Risiko: Nutzer werden getäuscht oder Sitzungen gekapert.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die Zuordnung der Schichten und Angriffe zu den drei Bereichen auswendig beherrschen (MAC/ARP → Zugang; IP/BGP/TCP/SYN → Transport; DNS/HTTP/Sessions → Anwendung).
- **Typische Klausurfälle:** Man-in-the-Middle (MITM) einer einzelnen Schicht zuzuordnen. MITM ist eine **Angreiferposition**, die man auf allen drei Ebenen erreichen kann!

? Mögliche Klausurfrage & Antwortskeizze

Frage: „Ordnen Sie die folgenden Begriffe den drei Bereichen ‚Zugang‘, ‚Transport‘ und ‚Anwendung‘ zu: (1) ARP-Spoofing, (2) SYN-Flood, (3) Session Hijacking.“ **Antwort:**

- (1) ARP-Spoofing: **Zugang** (OSI Schicht 2 / lokales Netz).
- (2) SYN-Flood: **Transport** (OSI Schicht 4 / TCP-Verbindungszustand).
- (3) Session Hijacking: **Anwendung** (OSI Schicht 7 / Web-Sitzungstoken).

Vier Fragen als roter Faden

- **Ereignis:** Was kann bei der Kommunikation schiefgehen?
- **Auswirkung:** Welche Folgen entstehen für Kunden und Geschäft?
- **Schutz:** Welches Sicherheitsprinzip reduziert das Risiko?
- **Beratung:** Welche Frage macht den Handlungsbedarf sichtbar?

Technische Details erklären das Wie. Für Entscheidungen zählt zuerst das Warum.

💡 Auf den Punkt gebracht (Einfach erklärt)

Dieses 4-Fragen-Raster ist dein universelles Denkwerkzeug für jedes Sicherheitsgespräch und jede Klausuraufgabe:

1. **Ereignis (Bedrohung):** Was passiert technisch? („Jemand leitet Daten heimlich um,“)
2. **Auswirkung (Schaden):** Was bedeutet das für das Geschäft? („Kundendaten fließen ab, DSGVO-Bußgelder, Vertrauensverlust,“)
3. **Schutz (Maßnahme):** Wie verhindern oder erkennen wir das? („Verschlüsselung, 802.1X, Segmentierung,“)
4. **Beratung (Audit):** Welche Frage deckt die Lücke beim Kunden auf? („Wissen Sie, wer sich im Besprechungsraum ans Kabel hängt?,“)

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Offene Klausurfragen strukturiert nach den Schritten Bedrohung → Auswirkung → Schutzmaßnahme → Risiko beantworten können.
- **Typische Klausurfälle:** Bei Prüfungsfragen nur ein Tool zu nennen („Kunde braucht Firewall,“), ohne die Auswirkung auf das Schutzgut und die Geschäftsprozesse zu begründen.

? Mögliche Klausurfrage & Antwortskizze

Frage: „Ein Angreifer fälscht Absender-IP-Adressen im Firmennetzwerk. Strukturieren Sie die Analyse dieses Vorfalls anhand von Ereignis, geschäftlicher Auswirkung und technischer Schutzmaßnahme.“ **Antwort:**

- **Ereignis: IP-Spoofing** (Vortäuschen einer fremden Identität auf Vermittlungsebene).
- **Auswirkung:** Umgehung von einfachen IP-Zugangsfiltren, mögliche Datenmanipulation oder Nutzung für DoS-Angriffe (**Verletzung von Integrität und Authentizität**).
- **Schutzmaßnahme: Kryptografische Authentifizierung (z. B. 802.1X / IPsec)** und **Ingress Filtering** beim Provider statt Vertrauen auf reine IP-Adressen.

Zugang und lokales Netz

Wer oder was darf sich verbinden?

Worum geht es in diesem Kapitel?

Wir beginnen ganz unten auf OSI-Schicht 1 und 2: Wer darf physisch oder per Funk in unser Netzwerk? Warum vertrauen Geräte im lokalen Netz einander blind und wie nutzen Angreifer dieses naive Urvertrauen mit MAC- und ARP-Spoofing aus?

Modul-Lernziel

Du lernst die Grundlagen von Schicht 1 und 2 kennen, verstehst den Unterschied zwischen MAC- und IP-Adresse und beherrschst die Funktionsweise von Network Access Control (802.1X).

Typische Schwerpunkte

Unterschied MAC-Adresse vs. IP-Adresse, Schwachstelle im ARP-Protokoll und der Ablauf von ARP-Spoofing.

Physischer Zugang ist Netzwerkzugang

- Frei zugängliche Netzwerkdosen können interne Verbindungen ermöglichen
- Unsicheres WLAN kann Daten preisgeben oder fremde Geräte hereinlassen
- Serverräume, Verteiler und Leitungen sind Ziele für Diebstahl oder Sabotage
- Schutz beginnt deshalb bei **Zutritt, Inventar und sicheren Funknetzen**

Beratungsfrage: Welche Netzwerkzugänge sind für Gäste und Dritte erreichbar?

💡 Auf den Punkt gebracht (Einfach erklärt)

Wer physischen Zugriff auf ein Kabel oder Funknetz hat, ist schon halb im System. Eine offene Netzwerkdose im Besucher-Besprechungsraum oder an einer Außenfassade kann reichen: Ein Angreifer steckt einen winzigen Minicomputer (z. B. Raspberry Pi) an und hat dauerhaften Zugriff auf das Firmennetz. **WLAN-Standards:** Veraltete Verschlüsselungen wie WEP und WPA sind in Sekunden geknackt. WPA2 ist das Minimum, **WPA3** der heutige Stand der Technik. **Gegenmaßnahme 802.1X (Network Access Control):** Der Switch schaltet den Netzwerkport erst frei, wenn sich das Gerät mit Zertifikat oder Benutzerdaten authentifiziert hat. Keine Autorisierung = tote Dose!

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die WLAN-Standards der Reihe nach bewerten können (WEP/WPA = unsicher; WPA2-Enterprise = Mindeststandard; WPA3 = aktuell) und **IEEE 802.1X / NAC** als Schutzmaßnahme für Switch-Ports nennen können.
- **Typische Klausurfalle:** Vergessen, dass physische Maßnahmen (abgeschlossene Verteilerkästen, Port-Abschaltung ungenutzter Dosen) vollwertige IT-Sicherheitsmaßnahmen sind!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Ein externer Besucher steckt im Besprechungsraum ein mitgebrachtes Notebook an eine freie Netzwerkdose. Mit welcher Technologie lässt sich verhindern, dass dieses fremde Gerät Zugriff auf das interne Unternehmensnetz erhält?“, **Antwort:**

- **Technologie: Network Access Control (NAC)** nach dem Standard **IEEE 802.1X**.
- **Funktionsweise:** Der Switch-Port bleibt standardmäßig blockiert; erst nach erfolgreicher Authentifizierung des Geräts (z. B. via Zertifikat) am zentralen RADIUS-Server wird der Datenverkehr freigegeben (oder in ein isoliertes Gastnetz geleitet).

Vertrauen im lokalen Netzwerk

- Geräte im selben Netz müssen einander finden und Daten austauschen
- Ältere Netzwerkmechanismen vertrauen vielen Angaben ohne Identitätsprüfung
- Ein fremdes Gerät kann sich dadurch als legitimer Kommunikationspartner ausgeben
- Mögliche Folgen: **Mitlesen, Manipulation oder Zugriff auf weitere Systeme**

Nähe im Netzwerk ist kein Beweis für Vertrauenswürdigkeit.

💡 Auf den Punkt gebracht (Einfach erklärt)

Im lokalen Netzwerk (LAN) müssen Computer wissen, welche Hardware-Adresse (**MAC-Adresse**) zu welcher IP-Adresse gehört. Dafür gibt es das **Address Resolution Protocol (ARP)**. Wenn dein PC drucken will, schreit er ins ganze Zimmer: „Wem gehört die IP 192.168.1.50?“. Der Drucker antwortet: „Mir, meine MAC-Adresse ist AA:BB:CC!“. *Das Problem:* ARP wurde vor 40 Jahren erfunden, als sich alle im Netz vertrauten. Es gibt **keine Authentifizierung, keine Signatur, keine Prüfung!** Jeder kann einfach rufen: „Ich bin der Drucker!“, – und alle glauben es ungeprüft.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Das Funktionsprinzip von ARP erklären und die fundamentale Sicherheitslücke benennen (**fehlende Authentifizierung / Vertrauen auf ungeprüfte Broadcast-Antworten**).
- **Typische Klausurfälle:** ARP-Spoofing für einen Programmierfehler halten. Es ist ein **Designfehler** eines historischen Protokolls, das für geschlossene, vertrauenswürdige Netze gebaut wurde!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Warum ist das Address Resolution Protocol (ARP) im lokalen Netzwerk anfällig für Manipulationen?“

„**Antwort:**

- **Fehlende Authentifizierung:** ARP-Nachrichten sind weder signiert noch verschlüsselt; die Identität des Absenders wird nicht überprüft.
- **Unaufgeforderte Antworten (Gratuitous ARP):** Geräte akzeptieren und speichern Antworten im **ARP-Cache**, selbst wenn sie nie danach gefragt haben.

Beispiel: Identität im Netzwerk vortäuschen

- Angreifer gibt sich im lokalen Netz als ein anderes Gerät aus
- Datenverkehr wird unbemerkt über den Angreifer geleitet
- Vergleichbar mit einer gefälschten Nachsendeadresse für Geschäftspost
- Risiken: Zugangsdaten mitlesen, Inhalte verändern, Kommunikation stören
- Fachbegriffe: **MAC-Spoofing** und **ARP-Spoofing**

💡 Auf den Punkt gebracht (Einfach erklärt)

- **MAC-Spoofing:** Dein PC ändert einfach seine eigene Netzwerk-Seriennummer (MAC-Adresse) und gibt sich z. B. als der Chef-Laptop oder als Drucker aus, um MAC-Filter zu überlisten.
- **ARP-Spoofing (ARP-Poisoning):** Der Angreifer schickt gefälschte Antworten an deinen PC: „Ich bin der Internet-Router!“. Gleichzeitig sagt er dem Router: „Ich bin der PC!“. Ab sofort schicken beide ihren gesamten Datenverkehr an den Angreifer, der alles mitliest und weiterleitet. *Alltagsanalogie:* Ein Dieb klebt heimlich ein Schild über den Briefkasten deines Nachbarn: „Nachsendeauftrag an Dieb“. Die Post liefert alle Briefe beim Dieb ab, er öffnet sie, liest sie durch und wirft sie danach beim echten Nachbarn ein.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** MAC-Spoofing und ARP-Spoofing unterscheiden und erklären, wie ARP-Spoofing zu einer **Man-in-the-Middle (MITM)-Position** führt.
- **Typische Klausurfalle:** Glauben, ARP-Spoofing funktioniere über das weltweite Internet. ARP funktioniert **nur im selben lokalen Netzwerksegment (Broadcast-Domäne / Subnetz)!**

? Mögliche Klausurfrage & Antwortskizze

Frage: „Erläutern Sie, wie ein Angreifer mittels ARP-Spoofing eine Man-in-the-Middle-Position im lokalen Netzwerk aufbaut, und nennen Sie die zwingende Voraussetzung für diesen Angriff.“ **Antwort:**

- **Ablauf:** Der Angreifer sendet gefälschte ARP-Antworten an das Opfer (behauptet, das Gateway zu sein) und an das Gateway (behauptet, das Opfer zu sein). Beide tragen die MAC-Adresse des Angreifers in ihren **ARP-Cache** ein; der Datenverkehr fließt über den Angreifer, der ihn nach dem Mitlesen transparent weiterleitet.
- **Voraussetzung:** Der Angreifer muss sich im **selben lokalen Netzwerksegment (Layer 2)** wie die Opfer befinden.

ARP-Spoofing als Diagramm

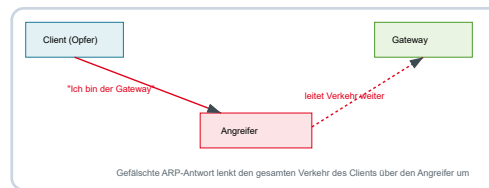


Abbildung 1: ARP-Spoofing als Diagramm

💡 Was zeigt uns diese Darstellung?

Das Diagramm visualisiert die heimliche Umleitung: Ursprünglich floss der Datenverkehr direkt zwischen dem Client (Opfer) und dem Gateway (Router). Durch die gefälschte ARP-Meldung schiebt sich der Angreifer als Dreieck dazwischen. Der Schlüssel zum Erfolg des Angriffs ist die gestrichelte Linie: Der Angreifer leitet die Pakete weiter, sodass das Opfer gar nicht merkt, dass jemand dazwischensitzt – das Internet funktioniert ja scheinbar normal weiter!

🔗 Klausurrelevanz (Transferaufgabe!)

- **Was du können musst:** Das Diagramm in drei Schritten erklären: (1) Gefälschte ARP-Antwort, (2) Umleitung über Angreifer, (3) Weiterleitung ans Gateway zur Tarnung.
- **Grenze des Angriffs:** Wenn der Datenverkehr mit TLS (HTTPS) verschlüsselt ist, kann der Angreifer nur Metadaten sehen, aber keine Passwörter mitlesen (außer das Opfer ignoriert Zertifikatswarnungen).

? Typische Fallfrage & Lösung

Frage: „Welchen Schutz bietet TLS (HTTPS), wenn sich ein Angreifer im lokalen Netzwerk erfolgreich per ARP-Spoofing zwischen Client und Gateway positioniert hat?“, **Antwort:**

- **Inhaltsschutz:** TLS verschlüsselt die Nutzdaten Ende-zu-Ende; der Angreifer sieht nur unleserlichen Chifretext und kann **keine Passwörter oder Inhalte im Klartext abfangen**.
- **Sichtbare Metadaten:** Der Angreifer sieht weiterhin Verbindungs-Metadaten (z. B. kontaktierte IP-Adressen, Paketgrößen, Zeitpunkte).
- **Voraussetzung:** Das Opfer darf gefälschte Zertifikate oder Zertifikatswarnungen im Browser **nicht wegklicken**.

Datenwege im Internet

Wem vertrauen wir beim Transport?

Worum geht es in diesem Kapitel?

Wir verlassen das Bürogebäude und betreten das globale Internet (OSI-Schicht 3). Sobald ein Datenpaket dein Firmennetz verlässt, reist es über 10 bis 20 fremde Router auf der ganzen Welt. Wie finden Pakete ihr Ziel? Was passiert, wenn Absenderadressen gefälscht werden (IP-Spoofing) oder digitale Wegweiser lügen (BGP-Hijacking)?

Modul-Lernziel

Du verstehst die Mechanismen der Vermittlungsschicht (IP, Routing), die Gefahren gefälschter Absender und warum der Transportweg grundsätzlich als unvertrauenswürdig eingestuft werden muss.

Typische Schwerpunkte

IP-Adressierung, IP-Spoofing (UDP vs. TCP), BGP-Hijacking und das Prinzip von Amplification- und Reflexionsangriffen.

Wie Daten ihr Ziel finden

- Daten werden in kleine Pakete aufgeteilt und über mehrere Stationen weitergeleitet
- **IP-Adressen** kennzeichnen Absender und Ziel
- Router wählen den verfügbaren Weg durch verschiedene Netze
- Unternehmen vertrauen dabei auf Infrastruktur außerhalb der eigenen Kontrolle

Schutz muss auch wirken, wenn der Transportweg nicht vertrauenswürdig ist.

💡 Auf den Punkt gebracht (Einfach erklärt)

Im Internet wird jede Datei in kleine Datenpakete zerlegt. Jedes Paket bekommt einen **IP-Header** mit Absender- und Ziel-IP-Adresse. Router auf der ganzen Welt lesen die Adresse und reichen das Paket weiter wie bei einer Eimerkette. *Wichtige Erkenntnis:* Das Internet Protocol (IP) ist **verbindungslos** und garantiert nichts („Best Effort“). Vor allem überprüft kein Router im Netz, ob die im Absenderfeld eingetragene IP-Adresse wirklich die echte Adresse des Absenders ist! *Schlussfolgerung:* Da der Transportweg fremden Betreibern gehört und unsicher ist, müssen Daten im Paket selbst geschützt werden (**Transportverschlüsselung / TLS**).

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Erklären können, warum Verschlüsselung die einzig verlässliche Antwort auf unkontrollierbare Transportwege ist und welche Informationen trotz Verschlüsselung sichtbar bleiben (**Metadaten:** Wer spricht mit wem, wann und wie viel?).
- **Typische Klausurfalle:** IP-Adresse als Identitätsnachweis ansehen. Eine IP-Adresse ist eine **Wegadresse**, kein beglaubigter Ausweis!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Warum kann ein Unternehmen dem Übertragungsweg von Datenpaketen im öffentlichen Internet grundsätzlich nicht vertrauen und welche Maßnahme schützt die Dateninhalte?“, **Antwort:**

- **Keine Kontrolle über Zwischenstationen:** Datenpakete passieren zahlreiche fremde Router und Provider, die manipuliert, abgehört oder fehlgeleitet werden können.
- **Schutzmaßnahme: Ende-zu-Ende-Verschlüsselung (z. B. TLS, IPsec)** schützt Vertraulichkeit und Integrität der Nutzdaten unabhängig vom Transportweg.

Gefälschte Absender

- Absenderangaben in Netzwerkpaketen können manipuliert werden
- Angreifer verschleiern damit ihre Herkunft oder missbrauchen Vertrauen
- Gefälschte Adressen können Antworten gezielt an ein Opfer lenken
- Deshalb darf eine Adresse allein keine Identität beweisen

Beratungsfrage: Welche Zugriffe vertrauen nur auf Herkunft oder Standort?

💡 Auf den Punkt gebracht (Einfach erklärt)

Beim **IP-Spoofing** schreibt der Angreifer eine fremde Absender-IP-Adresse in sein Datenpaket. Das ist so einfach wie eine falsche Absenderzeile auf einen Briefumschlag zu kritzeln. *Der Unterschied zwischen UDP und TCP:*

- Bei **UDP** (z. B. DNS, Streaming) braucht der Angreifer keine Antwort. Er schickt eine Anfrage mit der IP des Opfers los – die riesige Antwort knallt beim ahnungslosen Opfer ein!
- Bei **TCP** (Web, Mail) braucht man für die Verbindung eine Antwort. Bei gefälschtem Absender kommt die Antwort nie beim Angreifer an. Daher nutzt man IP-Spoofing bei TCP fast nur zur Verschleierung oder für DoS-Floods.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Erklären können, warum IP-Spoofing bei **verbindungslosen Protokollen (UDP)** besonders gefährlich ist und warum IP-basierte Zugangskontrollen unsicher sind.
- **Typische Klausurfälle:** Zu glauben, Firewalls könnten gefälschte IPs immer erkennen. Erst **Ingress Filtering (BCP 38)** beim Internet-Provider verhindert, dass Pakete mit gefälschten fremden IPs überhaupt ins Netz geschickt werden!

❓ Mögliche Klausurfrage & Antwortskizze

Frage: „Warum eignet sich das Protokoll UDP im Gegensatz zu TCP besonders gut für Angriffe mit gefälschten Absender-IP-Adressen (IP-Spoofing)?“ **Antwort:**

- **Verbindungslosigkeit von UDP:** UDP erfordert keinen Verbindungsaufbau (Handshake) und keine Rückbestätigung; Pakete werden einfach abgeschickt.
- **TCP erfordert Rückkanal:** Bei TCP muss der Drei-Wege-Handschlag abgeschlossen werden; Antworten auf gefälschte IPs würden das Opfer erreichen, sodass der Angreifer die Verbindung nicht aufbauen kann.

Wenn digitale Wegweiser falsch zeigen

- Netzbetreiber tauschen Informationen über erreichbare Ziele aus
- Fehlerhafte oder manipulierte Angaben können Verkehr umleiten
- Mögliche Folgen: **Ausfall, Verzögerung, Überwachung oder Manipulation**
- Unternehmen reduzieren das Risiko durch Verschlüsselung und belastbare Provider
- Fachbeispiel: **BGP-Hijacking**

💡 Auf den Punkt gebracht (Einfach erklärt)

Große Netzbetreiber (Telekom, Vodafone etc.) müssen wissen, welche IP-Adressen wo auf der Welt liegen. Dafür nutzen sie das **Border Gateway Protocol (BGP)** – das weltweite Navigationssystem des Internets. Beim **BGP-Hijacking** behauptet ein böswilliger oder schlampiger Provider plötzlich: „Die IP-Adressen von YouTube / Amazon liegen bei mir!“. Das weltweite Netz glaubt es, und der gesamte Verkehr wird umgeleitet. *Berühmtes Beispiel 2008:* Pakistan wollte YouTube im eigenen Land sperren, leitete versehentlich das weltweite Routing um – und legte YouTube weltweit für 2 Stunden lahm! 2018 wurde Amazon-DNS per BGP entführt, um Krypto-Nutzer auf Phishing-Seiten umzuleiten.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Den Begriff **BGP-Hijacking** erklären, als Lieferketten-/Infrastrukturrisiko einordnen und Gegenmaßnahmen nennen (**RPKI** = kryptografische Signatur von Routing-Routen, redundante Provider).
- **Typische Klausurfälle:** BGP-Hijacking für einen Angriff auf den Endkunden-Router halten. BGP läuft auf den **Core-Routern der großen Provider**!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Was versteht man unter ‚BGP-Hijacking‘ und welche geschäftlichen Auswirkungen können für ein betroffenes Unternehmen entstehen?“, **Antwort:**

- **Definition:** Fälschliche oder böswillige Ankündigung fremder IP-Adressbereiche im weltweiten Routing-Protokoll (BGP), wodurch Datenverkehr global umgeleitet wird.
- **Auswirkungen:** Vollständiger **Ausfall der Erreichbarkeit** (Denial of Service) oder unbemerktes **Abfangen und Manipulieren von Datenverkehr** (Man-in-the-Middle) durch den entführenden Knoten.

Kleine Anfrage, große Wirkung

- Angreifer nutzen viele fremde Systeme als unbeabsichtigte Verstärker
- Kleine Anfragen erzeugen zahlreiche oder deutlich größere Antworten
- Alle Antworten werden an die gefälschte Adresse des Opfers geschickt
- Ergebnis: Dienste werden langsam oder fallen vollständig aus

Das Angriffsziel ist **Verfügbarkeit**, nicht zwingend der Datendiebstahl.

💡 Auf den Punkt gebracht (Einfach erklärt)

Wie kann ein einzelner Angreifer mit einem billigen Laptop einen Großkonzern lahmlegen? Durch **Verstärkungsangriffe (Amplification & Reflection)**:

1. **Reflexion:** Der Angreifer schickt Anfragen mit der gefälschten Absender-IP des Opfers an Tausende öffentliche Server im Internet (z. B. DNS- oder NTP-Server).
2. **Amplifikation (Verstärkung):** Er nutzt Befehle, bei denen eine winzige Frage (z. B. 50 Byte) eine gigantische Antwort (z. B. 4.000 Byte = 80-fache Verstärkung!) erzeugt. *Ergebnis:* Tausende Server bombardieren gleichzeitig das Opfer mit einer Lawine von Antworten. Der Angreifer schwitzt nicht, das Opfer erstickt im Datenmüll.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die Begriffe **Reflexion** (Verschleierung + Weiterleitung über fremde Reflektoren) und **Amplifikation** (Vervielfachung der Datenmenge) trennscharf unterscheiden und erklären können.
- **Typische Klausurfalle:** Glauben, das Ziel sei Datendiebstahl. Amplification-Angriffe zielen rein auf die **Verfügbarkeit** (Überlastung / DoS)!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Erklären Sie den Unterschied zwischen ‚Reflexion‘ und ‚Amplifikation‘ bei einem verteilten Denial-of-Service-Angriff (DDoS).“ **Antwort:**

- **Reflexion:** Der Angriff wird über unbeteiligte Drittserver reflektiert, indem der Angreifer die **Absender-IP des Opfers fälscht**; dadurch wird die Identität des Angreifers verschleiert und das Opfer von tausenden Quellen gleichzeitig attackiert.
- **Amplifikation:** Das Antwortpaket des Drittserver ist **um ein Vielfaches größer als die Anfrage** (z. B. Faktor 50 bei DNS), wodurch der Datenstrom massiv vervielfacht wird.

Datenwege kontrollieren

- **Firewalls** prüfen Verbindungen anhand festgelegter Regeln
- Nur notwendige Kommunikationswege werden freigegeben
- Verschlüsselung schützt Inhalte auf fremden Transportwegen
- Überwachung erkennt ungewöhnliche Ziele, Mengen oder Muster
- Redundanz hält wichtige Dienste trotz einzelner Ausfälle erreichbar

💡 Auf den Punkt gebracht (Einfach erklärt)

Eine **Firewall** ist kein Wundermittel, sondern ein digitaler Türsteher mit einer strikten Gästeliste (**Access Control Lists / ACLs**). Das sicherste Grundprinzip lautet **Default Deny**: Alles ist grundsätzlich verboten, nur ausdrücklich genehmigte Verbindungen dürfen durch! *Firewall-Evolution*:

- **Paketfilter**: Prüft nur IP-Adresse und Portnummer (einfach, dumm).
- **Stateful Firewall**: Merkt sich bestehende Verbindungen und lässt Antworten nur durch, wenn vorher von innen gefragt wurde (Standard heute).
- **Next Generation Firewall (NGFW)**: Schaut tiefer und erkennt Anwendungen (z. B. „Erlaube WhatsApp, aber verbiete Datei-Downloads“).

🎯 Klausurrelevanz & Lernziel

- **Was du können musst**: Das Prinzip **Default Deny** begründen können und die Schutzziele zuordnen (Firewall = Zugangssteuerung; Verschlüsselung = Vertraulichkeit/Integrität; Monitoring = Erkennung; Redundanz = Verfügbarkeit).
- **Typische Klausurfalle**: Default Allow als Option akzeptieren. Default Allow ist extrem fehleranfällig, weil man jedes neue Risiko manuell sperren müsste!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Warum gilt das Prinzip ‚Default Deny‘ bei der Konfiguration von Firewall-Regeln als Best Practice im Vergleich zu ‚Default Allow‘?“ **Antwort**:

- **Default Deny**: Alles ist standardmäßig blockiert; nur explizit benötigte Ports und Dienste werden freigegeben. Neue, unbekannte Bedrohungen oder vergessene Dienste sind **automatisch geschützt**.
- **Default Allow**: Alles ist erlaubt, nur bekannte Gefahren werden gesperrt. Äußerst riskant, da jede neue Schwachstelle oder Konfigurationsänderung sofort ungeschützt offensteht.

Verfügbarkeit von Diensten

Wenn legitime Kommunikation zur Last wird

Worum geht es in diesem Kapitel?

Wir erreichen die OSI-Transportschicht (Schicht 4) mit TCP und UDP. Hier geht es um das Schutzziel Verfügbarkeit: Wie unterscheiden sich zuverlässige Telefonate (TCP) von schnellen Postkarten (UDP)? Warum kann man Server lahmlegen, ohne viel Bandbreite zu verbrauchen (SYN-Flood), und wie planen Unternehmen ihre Geschäftskontinuität (DDoS, SLAs, RTO, RPO)?

Modul-Lernziel

Du lernst die Unterschiede zwischen TCP und UDP kennen, verstehst Protokollangriffe (SYN-Flood) und kannst betriebliche Resilienz-Begriffe definieren.

Typische Schwerpunkte

TCP vs. UDP (Verbindungsorientierung vs. Zustandslosigkeit), 3-Wege-Handschlag und SYN-Cookies sowie DoS vs. DDoS und SLAs.

Zwei Arten der Datenübertragung

TCP

- Wie ein **Telefonat** mit Rückbestätigung
- Verbindung und Vollständigkeit werden geprüft
- Zuverlässig, aber mit zusätzlichem Aufwand
- Typisch für Webseiten und E-Mail

UDP

- Wie eine **Postkarte** ohne Empfangsbestätigung
- Daten werden direkt versendet
- Schnell, Verluste werden eher akzeptiert
- Typisch für Streaming und Namensabfragen

💡 Auf den Punkt gebracht (Einfach erklärt)

- **TCP (Transmission Control Protocol):** Funktioniert wie ein Telefonat mit Rückfrage. Erst verbindet man sich (3-Wege-Handschlag: „Hallo?“, – „Ja, hallo!“ – „Super, lass reden!“). Geht ein Wort verloren, bittet der Empfänger um Wiederholung. Perfekt für Webseiten, E-Mails und Banking.
- **UDP (User Datagram Protocol):** Funktioniert wie das Einwerfen einer Postkarte in den Briefkasten. Der Absender wirft sie ein und vergisst sie. Keine Bestätigung, keine Garantie. Dafür rasend schnell! Perfekt für Livestreams, Online-Gaming und DNS. *Die Sicherheitsfalle bei TCP:* Weil sich der Server jede offene Verbindung merken muss (**Zustand**), kann man seinen Speicher mit gefälschten Anfragen vollstopfen!

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die Gegenüberstellung verbindungsorientiert (TCP) vs. verbindungslos (UDP) mit Vor- und Nachteilen und je zwei typischen Protokollen beherrschen.
- **Typische Klausurfälle:** Annehmen, TCP sei immer sicherer als UDP. Die Zustandshaltung von TCP erzeugt eine eigene Angriffsfläche für Ressourcenerschöpfung (SYN-Flood)!

❓ Mögliche Klausurfrage & Antwortskizze

Frage: „Vergleichen Sie TCP und UDP anhand von Verbindungsaufbau, Fehlerkorrektur und typischen Einsatzgebieten.“ **Antwort:**

- **TCP: Verbindungsorientiert** (Drei-Wege-Handschlag); garantiert vollständige und geordnete Übertragung (**automatische Fehlerkorrektur**); Einsatz: HTTP/HTTPS, E-Mail, Dateiübertragung.
- **UDP: Verbindungslos** (kein Handshake); keine Zustellgarantie oder Fehlerbehebung (**geringer Overhead, minimale Latenz**); Einsatz: Videostreaming, VoIP, DNS.

Beispiel: Unvollständige Anfragen blockieren

- Ein Dienst reserviert Ressourcen für neue Verbindungen
- Angreifer starten massenhaft Verbindungen, führen sie aber nie zu Ende
- Offene Anfragen belegen Speicher und Verarbeitungskapazität
- Legitime Kunden werden langsam oder abgewiesen
- Fachbeispiel: **SYN-Flood**

💡 Auf den Punkt gebracht (Einfach erklärt)

Eine **SYN-Flood** ist ein fieser Protokollangriff auf TCP: Beim normalen Drei-Wege-Handschlag schickt der Client ein SYN (Anfrage), der Server reserviert Speicherplatz und antwortet mit SYN-ACK (Bestätigung), und der Client schließt mit ACK ab. Bei der SYN-Flood schickt der Angreifer tausende SYN-Pakete mit gefälschten Absender-IPs los, schickt aber **nie das finale ACK**. Der Server wartet geduldig, hält den Speicher reserviert, bis seine Verbindungstabelle platzt – und echte Kunden werden abgewiesen. *Alltagsanalogie:* Ein Anrufer reserviert in einem Restaurant unter 50 falschen Namen alle Tische für heute Abend, taucht aber nie auf. Echte Gäste müssen hungrig an der Tür abgewiesen werden. *Die Rettung: SYN-Cookies* – der Server merkt sich gar nichts mehr im Voraus, sondern packt die Reservierungsnummer verschlüsselt in die Antwort.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die drei Schritte des TCP-Handshakes (**SYN → SYN-ACK → ACK**) nennen, die Abbruchstelle des Angreifers markieren und **SYN-Cookies** als Gegenmaßnahme erklären können.
- **Typische Klausurfälle:** SYN-Flood für einen Bandbreitenangriff halten. Es ist ein **Ressourcen-/Zustandsangriff** – wenige Megabit reichen aus!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Erläutern Sie die Funktionsweise eines SYN-Flood-Angriffs und wie ‚SYN-Cookies‘ diesen Angriff abwehren.“ **Antwort:**

- **Funktionsweise:** Angreifer sendet massenhaft TCP-SYN-Pakete, beantwortet die SYN-ACK-Pakete des Servers aber nie mit dem abschließenden ACK. Die **Verbindungstabelle des Servers läuft voll**, legitime Verbindungen werden blockiert.
- **SYN-Cookies:** Der Server reserviert beim Eintreffen des SYN **keinen Speicherplatz**, sondern kodiert den Verbindungsstatus kryptografisch in die Sequenznummer; erst wenn das valide ACK des Clients eintrifft, wird die Verbindung aufgebaut.

Aufklärung vor dem Angriff

- Angreifer prüfen systematisch, welche Dienste erreichbar sind
- Vergleichbar mit dem Testen von Türen und Fenstern vor einem Einbruch
- Die Suche ist automatisiert und findet dauerhaft im Internet statt
- Unnötige Dienste vergrößern die Angriffsfläche
- Fachbegriff: **Portscan**

💡 Auf den Punkt gebracht (Einfach erklärt)

Ein **Port** ist wie eine Zimmernummer in einem Bürogebäude: IP-Adresse = Hausadresse; Port 80/443 = Webserver; Port 22 = Fernwartung (SSH); Port 3389 = Windows-Fernzugriff. Beim **Portscan** klopft ein Angreifer automatisiert an alle 65.535 Türen deines Servers und lauscht, wer „Herein!“, ruft. Meldet sich ein Dienst, liest der Angreifer oft sogar die genaue Versionsnummer ab (**Banner Grabbing**) und sucht gezielt nach bekannten Sicherheitslücken. *Verteidigung (Attack Surface Reduction)*: Schließe alle Türen, die du nicht brauchst! Dienste, die nur intern gebraucht werden, gehören hinter ein VPN und niemals offen ins Internet.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Den Begriff Portscan der Aufklärungsphase (**Reconnaissance**) zuordnen und das Prinzip der Angriffsflächenreduktion (**Attack Surface Reduction**) erläutern können.
- **Typische Klausurfalle:** Glauben, ein Portscan sei bereits ein Einbruch. Er ist reine **Informationsbeschaffung**, aber die unverzichtbare Vorstufe für gezielte Angriffe!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Was ist das Ziel eines Portscans und welche zwei Maßnahmen reduzieren die Angriffsfläche gegen automatisierte Scans?“, **Antwort:**

- **Ziel:** Identifikation von **offenen Netzwerkports, aktiven Diensten und deren Versionsnummern** zur Ermittlung potenzieller Schwachstellen.
- **Maßnahmen zur Reduktion:**
 1. **Abschalten nicht benötigter Dienste** (Hardening).
 2. **Zugriffsbeschränkung über Firewalls/VPN** (Dienste nur autorisierten IPs zugänglich machen, keine öffentliche Exposition).

Verfügbarkeit ist ein Geschäftsversprechen

- Online-Dienste müssen auch unter hoher Last erreichbar bleiben
- **DDoS-Angriffe** verteilen Überlastung auf viele Quellen
- Folgen: Umsatzverlust, Vertragsverletzungen, Supportaufwand, Vertrauensverlust
- Schutz: Kapazitätsreserven, Filterung, Notfallpläne und spezialisierte Anbieter

Beratungsfrage: Welche Ausfallzeit kann das Geschäft wirklich verkraften?

💡 Auf den Punkt gebracht (Einfach erklärt)

- **DoS vs. DDoS:** DoS kommt von einem einzelnen Rechner. **DDoS (Distributed DoS)** nutzt ein weltweites Botnetz aus hunderttausenden gekaperten Computern und Routern. Gegen DDoS hilft keine einfache IP-Sperre, weil der Angriff von überall gleichzeitig strömt!
- **Betriebliche Kennzahlen für Notfälle:**
 - **SLA (Service Level Agreement):** Die vertragliche Verfügbarkeitsgarantie (z. B. 99,9 % erlaubt max. 8,8 Stunden Ausfall pro Jahr!).
 - **RTO (Recovery Time Objective):** Wie schnell MUSS das System nach einem Ausfall wieder laufen? (Zeit bis zum Neustart).
 - **RPO (Recovery Point Objective):** Wie viel Datenverlust ist verkraftbar? (Wie alt darf das letzte Backup sein?).

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Den Unterschied zwischen DoS und DDoS erklären sowie RTO (Zeit bis Wiederherstellung) und RPO (akzeptabler Datenverlust) definieren können.
- **Typische Klausurfälle:** RTO und RPO verwechseln. **RTO = Zeit/Dauer des Ausfalls; RPO = Datenstand/Verlustzeitraum!**

? Mögliche Klausurfrage & Antwortskizze

Frage: „Unterscheiden Sie die Kennzahlen RTO (Recovery Time Objective) und RPO (Recovery Point Objective) anhand eines Ransomware-Vorfalls.“ **Antwort:**

- **RTO (Recovery Time Objective):** Die maximal tolerierbare Zeitspanne, bis die Systeme nach dem Vorfall **wieder voll betriebsbereit sein müssen** (z. B. Wiederanlauf innerhalb von 4 Stunden).
- **RPO (Recovery Point Objective):** Der maximal tolerierbare **Datenverlust**, gemessen als Zeitspanne zwischen letztem Backup und Vorfall (z. B. maximal 1 Stunde Datenverlust).

Anwendungen und Sitzungen

Wenn vertraute Dienste getäuscht werden

Worum geht es in diesem Kapitel?

Wir betreten die oberste Ebene (OSI-Schicht 7): Hier arbeiten echte Menschen mit Browsern, E-Mails und Web-Apps. Hier nützen reine Netzwerkfilter wenig, weil Angreifer menschliches Vertrauen und Anwendungslogik ausnutzen. Warum garantiert das Schloss-Symbol im Browser keine Sicherheit? Wie funktioniert Session Hijacking und warum ist DNS-Spoofing so gefährlich?

Modul-Lernziel

Du lernst die Mechanismen der Anwendungsschicht (HTTP-Sitzungen, Cookies, DNS) kennen und kannst Angriffe auf Vertrauen und Sitzungen von reinen Transportangriffen unterscheiden.

Typische Schwerpunkte

Zustandslosigkeit von HTTP, Schutz von Sitzungstoken (HttpOnly, Secure, SameSite), DNS-Spoofing vs. Cache-Poisoning und HTTP-Flood (Layer 7).

Nach dem Login: die digitale Sitzung

- Nach erfolgreicher Anmeldung merkt sich ein Dienst den Nutzer
- Ein **Sitzungstoken** dient vorübergehend als Nachweis der Anmeldung
- Wer dieses Token stiehlt, kann möglicherweise ohne Passwort handeln
- Verschlüsselung schützt das Token auf dem Transportweg
- Kurze Gültigkeit begrenzt den möglichen Schaden

💡 Auf den Punkt gebracht (Einfach erklärt)

Das Web-Protokoll HTTP ist **zustandslos**: Nach jedem Klick vergisst der Server sofort, wer du bist. Damit du dich nicht bei jedem Seitenwechsel neu einloggen musst, gibt dir der Server beim Login eine Wartenummer: ein **Sitzungstoken (Session Cookie)**. *Die Gefahr*: Wer dein Sitzungstoken klaut, ist in den Augen des Servers DU – ganz ohne dein Passwort zu kennen! *Die drei Schutzschilde für Cookies*:

- **HttpOnly**: JavaScript darf das Cookie nicht auslesen (Schutz gegen XSS).
- **Secure**: Cookie wird nur über verschlüsselte HTTPS-Verbindungen gesendet.
- **SameSite**: Verhindert, dass fremde Webseiten das Cookie ungefragt mitsenden (Schutz gegen CSRF).

🎯 Klausurrelevanz & Lernziel

- **Was du können musst**: Begründen können, warum Sitzungstoken existieren (Zustandslosigkeit von HTTP) und die drei Sicherheitsattribute (**HttpOnly**, **Secure**, **SameSite**) erklären können.
- **Typische Klausurfalle**: Glauben, Passwörter seien der einzige Angriffspunkt. Nach dem Login ist das **Sitzungstoken** das primäre Ziel von Angreifern!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Warum benötigt das Web-Protokoll HTTP Sitzungstoken und mit welchen zwei Cookie-Attributen lässt sich das Token gegen Diebstahl absichern?“ **Antwort**:

- **Grund**: HTTP ist ein **zustandsloses Protokoll**; ohne Token kann der Server aufeinanderfolgende Anfragen keinem authentifizierten Nutzer zuordnen.
- **Attribute**:
 - **HttpOnly**: Blockiert den Zugriff von clientseitigem JavaScript auf das Cookie (verhindert Diebstahl via **Cross-Site Scripting / XSS**).
 - **Secure**: Erzwingt die Übertragung des Cookies ausschließlich über verschlüsselte **HTTPS-Verbindungen**.

Beispiel: Eine angemeldete Sitzung übernehmen

- Angreifer erbeutet den temporären Nachweis einer Anmeldung
- Der Dienst hält den Angreifer anschließend für den legitimen Nutzer
- Eine starke Anmeldung allein verhindert diesen Missbrauch nicht
- Schutz: verschlüsselte Verbindung, sichere Endgeräte, kurze Sitzungen
- Fachbegriff: **Session Hijacking**

💡 Auf den Punkt gebracht (Einfach erklärt)

Beim **Session Hijacking** erbeutet ein Angreifer dein gültiges Sitzungstoken (z. B. durch Schadsoftware auf dem PC oder gefälschte Anmeldeseiten). Danach surft er mit deinen Rechten im System herum. *Wichtige Klausur-Erkenntnis: MFA (Zwei-Faktor-Authentifizierung) schützt hier NICHT!* Warum? Weil MFA nur beim Login an der Haustür geprüft wird. Wenn der Angreifer dir den Schlüsselbund (das Token) erst *nach* dem Aufschließen aus der Tasche zieht, ist die Tür bereits offen! *Schutz:* Kurze Sitzungsdauern, automatische Abmeldung und **Step-up-Authentifizierung** (für heikle Aktionen wie Überweisungen muss man nochmals einen Code eingeben).

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Erklären können, warum MFA vor Session Hijacking nach dem Login nicht schützt, und wirksame Gegenmaßnahmen nennen (**kurze Token-Lebensdauer, Re-Authentifizierung / Step-up-Auth**).
- **Typische Klausurfalle:** MFA als Allheilmittel für jede Phase eines Angriffs bezeichnen. MFA schützt den **Initial Login**, nicht das gestohlene Token danach!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Warum kann ein Angreifer eine Web-Sitzung mittels gestohlenem Session-Cookie übernehmen, selbst wenn das Benutzerkonto durch Mehrfaktor-Authentifizierung (MFA) geschützt ist?“, **Antwort:**

- **MFA schützt nur den Anmeldevorgang:** Die Zwei-Faktor-Prüfung erfolgt einmalig beim Erzeugen der Sitzung.
- **Token ersetzt Authentifizierung:** Das ausgegebene Sitzungstoken beweist dem Server den bereits erfolgreichen Login; wer das Token besitzt, umgeht alle vorgeschalteten Anmeldeschritte (**Session Hijacking**).

Die Anwendung schafft Vertrauen

- Nutzer sehen Namen, Inhalte und Marken – nicht die Netzwerkprotokolle dahinter
- Vertraute Oberflächen können Sicherheit vermitteln, aber auch gefälscht werden
- Anwendungen verarbeiten wertvolle Daten und geschäftliche Transaktionen
- Technik, Prozesse und Aufmerksamkeit der Nutzer müssen zusammenspielen

Eine funktionierende Verbindung garantiert noch kein vertrauenswürdiges Gegenüber.

💡 Auf den Punkt gebracht (Einfach erklärt)

Nutzer achten im Browser auf bekannte Logos, Farben und das grüne Vorhängeschloss in der Adresszeile. *Der fatale Denkfehler:* **Das Schloss-Symbol bedeutet NICHT, dass die Webseite seriös ist!** Es bedeutet ausschließlich: „Die Verbindung zu diesem Server ist verschlüsselt.“ Ein Betrüger kann sich in 30 Sekunden ein kostenloses, offizielles TLS-Zertifikat für `sparkasse-sicherheits-login.de` holen. Seine Fake-Seite hat ein perfektes Schloss! Sicherheit erfordert daher immer die Kombination aus technischer Prüfung, eindeutigen Domains und geschulten Nutzern.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Die Aussage „Eine verschlüsselte Verbindung garantiert kein vertrauenswürdiges Gegenüber,“ anhand eines Beispiels (Phishing-Webseite mit gültigem TLS-Zertifikat) begründen können.
- **Typische Klausurfälle:** Vertraulichkeit (Verschlüsselung des Kanals) mit Authentizität/Seriosität des Inhabers gleichsetzen!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Ein Mitarbeiter behauptet: ‚Die Webseite zeigt ein Schloss-Symbol im Browser, also ist sie sicher und vertrauenswürdig.‘ Nehmen Sie kritisch Stellung zu dieser Aussage.“ **Antwort:**

- **Aussage ist falsch:** Das Schloss-Symbol bestätigt lediglich, dass die Verbindung zum aufgerufenen Server per **TLS verschlüsselt** ist (**Schutz vor Abhören auf dem Transportweg**).
- **Keine Seriositätsprüfung:** Jeder Angreifer kann für betrügerische Domains (z. B. Phishing-Seiten) gültige TLS-Zertifikate beantragen; das Schloss sagt nichts über die **Echtheit oder Gutartigkeit des Betreibers** aus.

Beispiel: Der richtige Name, das falsche Ziel

- Das **Domain Name System (DNS)** übersetzt Namen in technische Zieladressen
- Manipulierte Antworten können Nutzer zu einem falschen Dienst leiten
- Der eingegebene Name kann dabei korrekt erscheinen
- Mögliche Folgen: Zugangsdaten- oder Zahlungsdatendiebstahl
- Fachbegriffe: **DNS-Spoofing** und **Cache-Poisoning**

💡 Auf den Punkt gebracht (Einfach erklärt)

Das **Domain Name System (DNS)** ist das Telefonbuch des Internets: Du tippst `meinebank.de` ein, und DNS liefert die IP-Adresse `192.0.2.1`.

- **DNS-Spoofing:** Ein Angreifer im selben Netz fängt deine Anfrage ab und ruft schnell: „Die Bank liegt auf meiner IP!“, Du tippst die richtige Adresse ein, landest aber auf der Betrüger-Kopie.
- **Cache-Poisoning:** Der Angreifer vergiftet den Zwischenspeicher (Cache) des Internet-Anbieters. Ab jetzt werden **tausende Kunden** tagelang zur gefälschten Bank geleitet! *Die Lösung:* **DNSSEC** versieht DNS-Antworten mit einer digitalen Signatur – gefälschte Antworten fliegen sofort auf.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** DNS-Spoofing (lokal, einzelnes Opfer) und Cache-Poisoning (Resolver-Cache vergiftet, massenhafte Opfer) unterscheiden und **DNSSEC** als Schutzmaßnahme nennen können.
- **Typische Klausurfalle:** Den Fehler beim Nutzer suchen. Bei DNS-Angriffen gibt der Nutzer die **exakt richtige Webadresse** ein – das System leitet ihn technisch falsch um!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Grenzen Sie ‚DNS-Spoofing‘ von ‚DNS-Cache-Poisoning‘ ab und nennen Sie die Standardtechnologie zur Absicherung der Namensauflösung.“ **Antwort:**

- **DNS-Spoofing:** Fälschen einer einzelnen DNS-Antwort für einen bestimmten Client (meist im lokalen Netz).
- **DNS-Cache-Poisoning:** Einschleusen gefälschter DNS-Einträge in den **Zwischenspeicher (Cache) eines DNS-Resolvers/Servers**, wodurch **alle nachfolgenden Nutzer** dieses Servers unbemerkt auf gefälschte Zieladressen geleitet werden.
- **Schutztechnologie:** **DNSSEC (Domain Name System Security Extensions)** durch kryptografische Signaturen von DNS-Einträgen.

Ein Muster, verschiedene Angriffswege

- Angreifer positioniert sich unbemerkt zwischen zwei Kommunikationspartnern
- Er kann Daten mitlesen, verändern oder an ein falsches Ziel leiten
- Der Einstieg ist über WLAN, lokales Netz oder Namensauflösung möglich
- **Ende-zu-Ende-Verschlüsselung** schützt den Inhalt über unsichere Wege

Fachbegriff: **Man-in-the-Middle (MITM)**

💡 Auf den Punkt gebracht (Einfach erklärt)

Man-in-the-Middle (MITM) – heute oft neutral **Adversary-in-the-Middle (AiTM)** genannt – ist kein einzelnes Tool, sondern eine strategische **Position**: Der Angreifer sitzt heimlich zwischen zwei Partnern, liest alles mit oder ändert Nachrichten nach Belieben. *Viele Wege führen zum selben Ziel:*

- Auf Schicht 2 über **ARP-Spoofing** oder ein gefälschtes WLAN (Evil Twin).
- Auf Schicht 3 über **BGP-Hijacking**.
- Auf Schicht 7 über **DNS-Spoofing**. *Die stärkste Waffe dagegen: **Ende-zu-Ende-Verschlüsselung mit strikter Zertifikatsprüfung (TLS)***. Der Angreifer kann dazwischensitzen wie er will – er hat den privaten Schlüssel nicht und kann die Daten weder lesen noch unbemerkt verändern.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** MITM als **übergeordnete Position** definieren, mindestens drei verschiedene Wege dorthin aufzählen und erklären, wie TLS dagegen schützt.
- **Typische Klausurfälle:** MITM einer einzelnen Schicht zuordnen. MITM kann auf **Layer 2, Layer 3 oder Layer 7** entstehen!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Nennen Sie drei verschiedene technische Wege auf unterschiedlichen Netzwerkschichten, über die ein Angreifer eine Man-in-the-Middle-Position erlangen kann.“ **Antwort:**

1. **Layer 2 (Zugang): ARP-Spoofing** oder Bereitstellung eines gefälschten WLAN-Access-Points (**Evil Twin**).
2. **Layer 3 (Transport): BGP-Hijacking** (Umleitung des IP-Routings im Internet).
3. **Layer 7 (Anwendung): DNS-Spoofing / Cache-Poisoning** (Fälschung der Namensauflösung).

Wenn normale Anfragen zum Angriff werden

- Angreifer senden massenhaft scheinbar legitime Anfragen an eine Anwendung
- Einzelne Anfragen wirken unauffällig, ihre Menge überlastet den Dienst
- Botnetze verteilen den Verkehr auf viele Geräte und Regionen
- Schutz erfordert Erkennung, Skalierung und klare Prioritäten für kritische Dienste
- Fachbeispiel: **HTTP-Flood**

💡 Auf den Punkt gebracht (Einfach erklärt)

Bei einer **HTTP-Flood** (Layer-7-DDoS) schicken hunderttausende infizierte Computer (Botnetze) scheinbar völlig normale Anfragen an einen Webserver – z. B. starten sie gleichzeitig aufwendige Datenbank-Suchen oder rufen den Produktkatalog ab. *Warum ist das so schwer abzuwehren?* Jede einzelne Anfrage ist formal 100 % legal! Eine normale Firewall sieht ganz normalen Webverkehr auf Port 443. Aber die Datenbank bricht unter der Last zusammen, weil jede Anfrage viel Rechenleistung frisst (**Asymmetrie des Aufwands**). *Schutz:* **Web Application Firewalls (WAF)**, Bot-Erkennung (z. B. CAPTCHAs, Verhaltensanalyse) und Ratenbegrenzung (**Rate Limiting**).

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Den Unterschied zwischen volumetrischen Angriffen (Layer 3/4, rohe Bandbreite) und **Layer-7-Angriffen (HTTP-Flood, Anwendungsressourcen)** erklären können.
- **Typische Klausurfalle:** Annehmen, eine Netzwerk-Firewall könne eine HTTP-Flood stoppen. Eine Layer-3/4-Firewall sieht nur erlaubte TCP-Port-443-Pakete – man braucht eine **WAF**!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Warum versagt eine klassische Netzwerk-Firewall bei der Abwehr einer HTTP-Flood und welche spezialisierte Sicherheitskomponente wird stattdessen benötigt?“, **Antwort:**

- **Versagen der Netzwerk-Firewall:** Die Anfragen sind formal gültige HTTP/HTTPS-Pakete auf erlaubten Standardports (Port 80/443); die Firewall kann bösartige Absichten nicht auf Anwendungsebene interpretieren.
- **Lösung:** Eine **Web Application Firewall (WAF)** oder spezialisierte DDoS-Schutzdienste, die das Verhalten analysieren, Bot-Muster erkennen und **Rate Limiting / Challenge-Response (CAPTCHA)** erzwingen.

Verteidigung im Überblick

Mehrere Schutzlinien gleichzeitig

Worum geht es in diesem Kapitel?

Im Finale führen wir alle Puzzleteile zu einem ganzheitlichen Schutzkonzept zusammen: Kein Produkt der Welt schützt vor allem. Wir lernen das goldene Prinzip **Defense in Depth** kennen, ordnen Maßnahmen nach ihrer Wirkung (Vorbeugen, Begrenzen, Erkennen, Reagieren, Lernen) und klären den Unterschied zwischen Netzwerksegmentierung und Zero Trust.

Modul-Lernziel

Du kannst ein mehrschichtiges Sicherheitskonzept nach dem Defense-in-Depth-Prinzip entwerfen, Schutzmaßnahmen nach technischen, organisatorischen und personellen Kriterien strukturieren und Beratungsgespräche führen.

Typische Schwerpunkte

Defense in Depth Definition + Schichten, IDS vs. IPS (Erkennen vs. Blockieren), Segmentierung (VLANs, Mikrosegmentierung) und das 5-Stufen-Modell der Wirkung.

Defense in Depth

- **Defense in Depth** kombiniert mehrere unabhängige Schutzmaßnahmen
- Vorbeugen, Erkennen, Begrenzen und Wiederherstellen ergänzen sich
- Versagt eine Maßnahme, verhindert die nächste den Totalschaden
- Menschen, Prozesse, Technik und Dienstleister tragen gemeinsam bei

Nicht die Anzahl der Produkte zählt, sondern das Zusammenspiel der Kontrollen.

💡 Auf den Punkt gebracht (Einfach erklärt)

Defense in Depth bedeutet: Baue niemals nur eine einzige Schutzmauer! Wenn du dich nur auf deine Firewall verlässt und sie versagt, ist sofort alles verloren. Stattdessen staffeln wir unabhängige Schutzebenen hintereinander: Firewall am Rand → Netzwerksegmentierung im Inneren → Virenschutz & Patching auf dem PC → Verschlüsselung & Rechteprüfung an der Datei. *Schweizer-Käse-Modell*: Jede Sicherheitsschicht hat Löcher (Schwachstellen). Aber wenn man mehrere Scheiben hintereinanderlegt, deckt eine Scheibe die Löcher der anderen ab – ein Angriff dringt nicht bis zu den Kronjuwelen durch.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Das Prinzip **Defense in Depth** definieren, von reiner „Produktvielfalt“, abgrenzen und die Notwendigkeit **unabhängiger Kontrollen** betonen.
- **Typische Klausurfalle:** Drei Firewalls desselben Herstellers hintereinander zu schalten. Echte Defense in Depth braucht **voneinander unabhängige Kontrollen** auf verschiedenen Ebenen!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Definieren Sie das Sicherheitsprinzip ‚Defense in Depth‘ und erklären Sie, warum die Unabhängigkeit der eingesetzten Schutzmaßnahmen entscheidend ist.“ **Antwort:**

- **Definition:** Gestaffeltes Sicherheitskonzept aus **mehreren redundanten, aufeinander aufbauenden Schutzschichten** (z. B. Perimeter, Netzwerk, Host, Daten), damit das Versagen einer Schicht nicht zum Gesamtschaden führt.
- **Unabhängigkeit:** Verhindert einen **Single Point of Failure**; hängen alle Maßnahmen von derselben Technologie oder demselben System ab, kann ein einziger Fehler alle Schutzlinien gleichzeitig aushebeln.

Defense in Depth als Diagramm

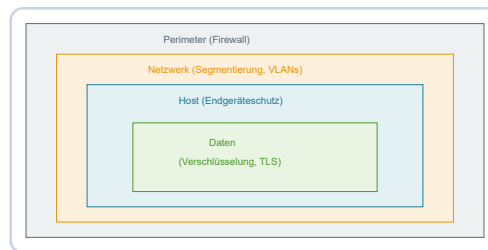


Abbildung 2: Defense in Depth als Diagramm

💡 Was zeigt uns diese Darstellung?

Die Grafik visualisiert Defense in Depth als vier ineinander verschachtelte Zwiebelschalen:

1. **Perimeter (Außen)**: Firewall fängt grobe Angriffe aus dem Internet ab.
2. **Netzwerk (Mitte außen)**: Segmentierung & VLANs stoppen die Ausbreitung (Lateral Movement).
3. **Host (Mitte innen)**: Endgeräteschutz (EDR, Patches) sichert den einzelnen Laptop/Server.
4. **Daten (Kern)**: Starke Verschlüsselung und Zugriffsrechte schützen das eigentliche Juwel – selbst wenn alle drei äußeren Mauern gefallen sind!

🔗 Klausurrelevanz (Transferaufgabe!)

- **Was du können musst**: Die vier Schalen von außen nach innen benennen und für jede Ebene eine typische Maßnahme sowie deren Restrisiko erklären können.
- **Kritische Reflexion**: Das Burg-Modell muss heute durch mobile Kontrollen und Zero Trust ergänzt werden, da viele Hosts gar nicht mehr hinter dem Perimeter stehen.

? Typische Fallfrage & Lösung

Frage: „Ein Angreifer überwindet die externe Firewall über eine legitime HTTPS-Verbindung mit gestohlenen Zugangsdaten. Welche zwei inneren Schutzschichten greifen laut Defense-in-Depth-Modell als Nächstes?“

„**Antwort**:“

- **Netzwerk-Ebene: Segmentierung (VLANs / ACLs)** verhindert, dass der kompromittierte Einstiegspunkt andere sensible Bereiche (z. B. Datenbanken, Produktionsnetz) erreicht.
- **Host-/Daten-Ebene: Least Privilege / Autorisierungsprüfung und Verschlüsselung** stellen sicher, dass mit den gestohlenen Rechten nur minimale Daten eingesehen werden können.

Schutzmaßnahmen nach ihrer Wirkung

Ziel	Beispiele	Nutzen
Vorbeugen	sichere Konfiguration, Firewall, Verschlüsselung	Eintritt erschweren
Begrenzen	Segmentierung, minimale Rechte	Ausbreitung stoppen
Erkennen	Protokollierung, Netzwerküberwachung	Vorfälle sichtbar machen
Reagieren	Notfallplan, DDoS-Dienstleister	Ausfallzeit verkürzen
Lernen	Tests, Übungen, Verbesserungsprozess	Wiederholung vermeiden

💡 Auf den Punkt gebracht (Einfach erklärt)

Ein gutes Sicherheitskonzept ist wie eine Notfalkette im Krankenhaus – es reicht nicht, nur Vitamine zu schlucken (Vorbeugen), man braucht auch Diagnostik (Erkennen) und eine Notaufnahme (Reagieren):

- **Vorbeugen (Prävention):** Firewall, Verschlüsselung, Härtung (Eintritt verhindern).
- **Begrenzen (Kapselung):** Segmentierung, Least Privilege (Schaden eindämmen).
- **Erkennen (Detektion):** SIEM, IDS, Logging (Angriff bemerken).
- **Reagieren (Response):** Notfallplan, DDoS-Mitigation (Systeme retten).
- **Lernen (Recovery / Review):** Post-Mortem, Backup-Tests (beim nächsten Mal besser sein). *Wichtig: IDS (Detection) schlägt nur Alarm; IPS (Prevention) greift aktiv ein und blockiert verdächtigen Verkehr sofort!*

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Den Unterschied zwischen **IDS** (nur erkennen/melden) und **IPS** (aktiv blockieren) kennen und Maßnahmen den 5 Wirkungsstufen zuordnen können.
- **Typische Klausurfälle:** Glauben, Erkennung (Logging/SIEM) allein schütze das System. Ohne definierten **Reaktionsprozess** verpufft jeder Alarm wirkungslos!

? Mögliche Klausurfrage & Antwortskizze

Frage: „Unterscheiden Sie ein Intrusion Detection System (IDS) von einem Intrusion Prevention System (IPS) und ordnen Sie beide den jeweiligen Wirkungskategorien zu.“ **Antwort:**

- **IDS:** Überwacht den Datenverkehr passiv und generiert Alarme bei verdächtigen Mustern; Wirkungskategorie: **Erkennen (Detektion)**.
- **IPS:** Sitzt aktiv im Datenstrom (inline) und kann verdächtige Pakete oder Verbindungen in Echtzeit verwerfen; Wirkungskategorie: **Vorbeugen / Abwehren (Prävention)**.

Netzwerksegmentierung & Zero Trust

- **Segmentierung** trennt Bereiche mit unterschiedlichen Aufgaben und Risiken
- Beispiel: Gäste, Büroarbeitsplätze, Produktion und kritische Server
- **Zero Trust** prüft Zugriffe anhand von Identität, Gerät und Kontext
- Gemeinsam reduzieren beide die unkontrollierte Ausbreitung eines Angriffs

Beratungsfrage: Was kann ein kompromittierter Arbeitsplatz im internen Netz erreichen?

💡 Auf den Punkt gebracht (Einfach erklärt)

- **Netzwerksegmentierung:** Das Prinzip der **Brandschutztüren**. Wenn im Büro ein Feuer ausbricht (ein Laptop wird mit Ransomware infiziert), fällt die Brandschutztür zu – das Feuer greift nicht auf die Fabrikhalle oder die Finanzdaten über. Technisch gelöst über VLANs und interne Firewalls.
- **Zero Trust:** Die Weiterentwicklung. Hier gibt es nicht nur Zonen, sondern jede einzelne Ressource verlangt bei jedem Zugriff den Ausweis: „Bist du der Admin? Ist dein Virens Scanner aktuell? Ja? Dann darfst du für 5 Minuten rein.“ *Zusammenfassung:* Segmentierung kontrolliert die **Wege im Netz**; Zero Trust kontrolliert den **Zugriff auf die Ressourcen**.

🎯 Klausurrelevanz & Lernziel

- **Was du können musst:** Erklären können, warum Segmentierung die wirksamste Maßnahme gegen **Ransomware-Ausbreitung (Lateral Movement)** ist, und Segmentierung sauber von Zero Trust abgrenzen.
- **Typische Klausurfälle:** Behaupten, Segmentierung verhindere den Einbruch. Segmentierung verhindert nicht das Feuer, sondern den **Flächenbrand**!

? Mögliche Klausurfrage & Antwortschizze

Frage: „Warum ist die Netzwerksegmentierung eine der wirksamsten Einzelmaßnahmen zur Begrenzung von Ransomware-Schäden in Unternehmen?“ **Antwort:**

- **Eindämmung von Lateral Movement:** Ransomware breitet sich nach dem Erstbefall automatisiert über offene Netzwerkverbindungen im lokalen Netz aus.
- **Schadensbegrenzung:** Durch Segmentierung (z. B. Trennung von Office-Clients, Servern und Backups) wird die Ausbreitung an internen Firewall-Grenzen gestoppt; ein Befall bleibt auf das infizierte Subnetz beschränkt (**Brandschutz-Prinzip**).

Zusammenfassung

Bereich	Kernrisiko	Leitfrage
Zugang	fremde oder kompromittierte Geräte	Wer oder was darf sich verbinden?
Transport	Umleitung, Mitlesen, Überlastung	Wie bleiben Daten und Dienste geschützt?
Anwendung	Täuschung und Sitzungsübernahme	Ist das Gegenüber wirklich vertrauenswürdig?
Organisation	unklare Reaktion und Abhängigkeiten	Wer handelt bei einem Vorfall?

Merksatz: Netzwerksicherheit schützt Geschäftskontinuität, Daten und Vertrauen.

Schnell-Check

- **Zugang:** Schütze Hardware, Dosen und WLAN (WPA3, 802.1X). Sei dir bewusst: ARP und MAC bieten kein Vertrauen!
- **Transport:** Gehe davon aus, dass der Weg durchs Internet unsicher ist. Vertraue keiner IP-Adresse blind (IP-Spoofing, BGP-Hijacking) und nutze konsequent **TLS**.
- **Anwendung:** Schütze Sitzungstoken (HttpOnly, Secure) und sichere die Namensauflösung (DNSSEC). Das Schloss im Browser garantiert keine Seriosität!
- **Organisation & Architektur:** Setze auf **Defense in Depth**, **Segmentierung** und **Zero Trust**. Technik ohne Notfallprozesse versagt im Ernstfall.

Prüfungs-Checkliste

- ☐ Kannst du die Angriffe der Dreiteilung *Zugang / Transport / Anwendung* zuordnen?
- ☐ Kannst du ARP-Spoofing und SYN-Flood Schritt für Schritt erklären?
- ☐ Weißt du, warum MFA nicht gegen Session Hijacking nach dem Login schützt?
- ☐ Beherrschst du die Begriffe *Defense in Depth*, *Zero Trust*, *SLA*, *RTO* und *RPO*?
- ☐ Kannst du die Brandschutztüren-Analogie für Netzwerksegmentierung erklären?

Blitzfragen zur Selbstkontrolle

1. Welches Schutzziel der CIA-Triade wird bei einem BGP-Hijacking verletzt, wenn der Verkehr ins Leere geleitet wird vs. wenn er heimlich mitgelesen wird? → Ins Leere = **Verfügbarkeit**; Mitlesen = **Vertraulichkeit** (und ggf. Integrität).
2. Warum hilft DNSSEC gegen Cache-Poisoning? → Weil DNSSEC die DNS-Einträge mit **kryptografischen Signaturen** versieht; gefälschte Antworten des Angreifers werden vom Resolver verworfen.

Diskussionsfragen

- Welcher netzwerkbedingte Ausfall hätte bei eurem Partnerunternehmen die größten Folgen?
- Mit welchen drei Fragen würdet ihr ein erstes Kundengespräch beginnen?
- Wo könnte sich ein Angreifer nach einem erfolgreichen Einstieg weiter ausbreiten?
- Wie würdet ihr den Nutzen von Segmentierung ohne Fachbegriffe erklären?
- Welche Schutzmaßnahme benötigt zwingend einen organisatorischen Prozess?

Beratungs- & Diskussionsfokus

Diese Fragen spiegeln reale Kundengespräche im IT-Consulting wider: Ein Geschäftsführer fragt nicht nach Portnummern, sondern will wissen: „Was kostet mich ein Tag Stillstand? Warum reichen unsere alten Firewalls nicht mehr? Wie verhindern wir, dass der Hacker vom Drucker an die Buchhaltung kommt?„

Lernziel (Transfer & Argumentation)

Du kannst technische Schutzmaßnahmen in überzeugende geschäftliche Argumente übersetzen, ohne in unverständlichen Fachjargon zu verfallen.

Typische Beratungsfragen & Kernargumente

- **Frage 1: „Wie erkläre ich Segmentierung ohne Fachchinesisch?„** → *Kernargument: Brandschutztüren-Prinzip.* Wenn in der Teeküche ein Papierkorb brennt, brennt nicht gleich das ganze Fabrikgebäude ab.
- **Frage 2: „Warum reicht unsere Firewall nicht aus?„** → *Kernargument: Die Firewall steht nur am Haupteingang. Wenn der Angreifer per Phishing oder über das Homeoffice eines Mitarbeiters bereits im Wohnzimmer steht, schützt der Zaun im Vorgarten nicht mehr (Notwendigkeit von Zero Trust & internen Kontrollen).*